ITECH1502 Final Project Report: Vulnerability Scanning with Nmap, Nikto and OpenVAS

Student: Senuri Mehara Hewa Dewage | **Student number:** 30492560 | **Unit:** ITECH1502 Cybersecurity Fundamentals | **Platform:** TryHackMe | **Portfolio:** https://github.com/Mehara26/Cybersecurity-Portfolio

Summary

This project documents a hands-on vulnerability assessment completed on TryHackMe using the Vulnerability Scanning Tools room. The aim was to learn how three widely used tools, Nmap, Nikto and OpenVAS, identify weaknesses in a target system and how the results are interpreted and prioritised. Working against an authorised lab machine, I mapped five exposed services with Nmap, checked the web server with Nikto, and analysed a pre-scanned OpenVAS report that rated findings using CVSS and CVE references. The main findings were anonymous FTP login (CVSS 6.4, Medium), an exposed phpinfo page (5.3, Medium), a session cookie without the HttpOnly flag, and several web server misconfigurations. Several of these were reported independently by more than one tool, which increased my confidence in them. The OpenVAS scan could not be run live because the lab had no internet access for feed updates, so I reviewed the room's pre-scanned report instead. I completed all seven tasks of the room. The project strengthened my ability to run scans, interpret output and recommend practical fixes, and it supports my goal of working in a security operations role.

1. Introduction

I chose TryHackMe because it lets me practise real security tools in a safe and legal way. Each "room" gives short lessons and a virtual machine I am allowed to scan, which matters because scanning systems you do not own can be a crime. I had already used it in earlier labs for this unit, and the free version was enough. I picked the Vulnerability Scanning Tools room because scanning is one of the first steps in any security check, and the room teaches three tools together: Nmap (finds what a system exposes), Nikto (checks web servers) and OpenVAS (rates how serious each weakness is).

2. Problem / Challenge

The task was to run a first vulnerability check on one lab machine, the way a security analyst would at the start of a job. The machine runs an FTP server, an SSH server, a VNC service and a web app called AtlasNews. I had to find what is exposed, spot weaknesses and explain what the results mean. This matters because attackers scan for weak systems all the time, and scanners produce a lot of output, so the real skill is deciding what is real, how serious it is and what to fix first. It links to the unit outcomes on scanning tools (S2), security measures (S1), analysing findings and suggesting fixes (A1, A2), and legal and ethical practice (K4).

3. Project Goal and Objectives

My overall goal was to learn how vulnerability scanning works in practice and to practise turning raw scan output into prioritised, actionable findings. To achieve this I set four objectives:

1. Use Nmap to discover the target, list its open ports and identify the service versions running on them.
2. Use Nikto to check the target's web server for misconfigurations and exposed files.
3. Read an OpenVAS report to understand CVE identifiers and CVSS severity ratings and rank the findings by risk.

4. Recommend a practical fix for each main finding, while keeping all scanning within the authorised lab environment.

4. Methodology

I registered with my FedUni email, started the lab machine and worked from quiet checks to deeper ones, choosing each step based on the last result. This covers vulnerability scanning and the first stages of a penetration test (discovery and enumeration). I did not exploit anything, which kept the work safe and within the lab's rules.

Step	Command or tool	Why I did it
1. Check the machine is on	`nmap -sn <target IP>`	A light check before sending more traffic.
2. Find open ports and versions	`nmap -sV <target IP>`	Known weaknesses depend on software versions.
3. Get more detail	`nmap -A <target IP>`	Adds scripts and banners (FTP, cookie details); noisier, so done later.
4. Test FTP	`nmap --script=ftp-anon -p21 <target IP>`	Checks if anyone can log in to FTP without an account.
5. Check the web server	`nikto -h http://<target IP>:8080`	Nmap found a website on port 8080, and Nikto is made for web checks.
6. Rate the risks	OpenVAS in the lab browser	Gives each finding a CVE ID and CVSS score. I set up a target and task, then studied the room's pre-scanned report.

Two things did not go to plan. I first opened OpenVAS in my own browser and got an error, because 127.0.0.1 means "this computer", so I had to open it inside the lab machine. Then the lab machine restarted and its IP changed (Nmap and Nikto used 10.146.135.144, OpenVAS used 10.146.148.132), and my OpenVAS scan could not run because the scanner was still updating its feeds without internet, as the room had warned.

Legal and ethical approach (K4). I only scanned the lab machine TryHackMe provides. Scanning systems without permission can break computer crime laws, such as Part 10.7 of the Criminal Code Act 1995 (Cth). I started with gentle scans, did not try to exploit anything, and treated scanner results as things to check, not proof. I also read the room's safe-scanning practices (Task 6).

5. Results and Outcomes

The tools backed each other up on the main problems, and I completed all seven room tasks (100%).

Nmap. The service scan found five open ports (995 were closed): 21 FTP (vsftpd 3.0.5), 22 SSH (OpenSSH 9.6p1), 80 HTTP (WebSockify, which Nmap could not fully identify), 5901 VNC, and 8080 HTTP (Apache 2.4.58 running AtlasNews).

The deeper scan showed that anonymous FTP login is allowed, FTP sends data in plain text, and the web session cookie (PHPSESSID) has no HttpOnly flag. The `ftp-anon` script confirmed "Anonymous FTP login allowed (FTP code 230)".

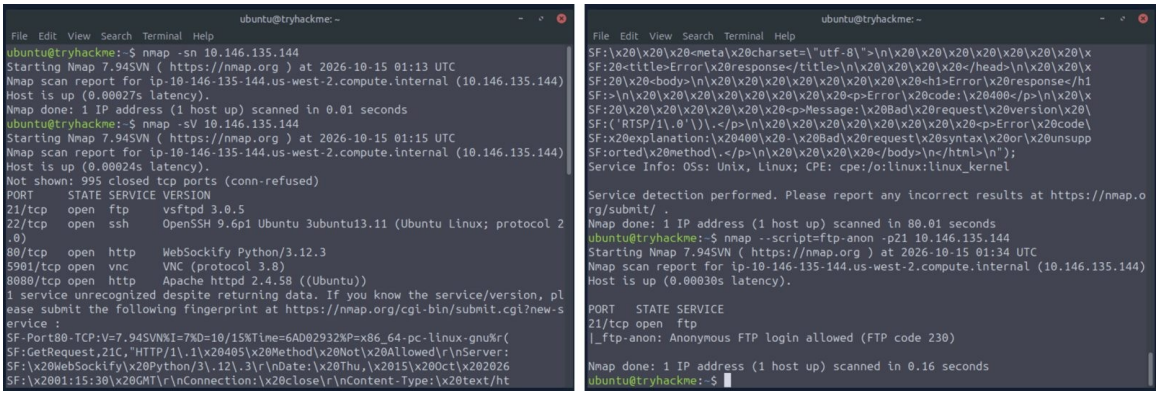


Figure 1: Nmap -sV (left) and the ftp-anon script (right), showing code 230.

Nikto. On port 8080, Nikto ran 6,544 checks in about 8 seconds and reported seven items: the same cookie without HttpOnly, a missing X-Frame-Options header, the DEBUG method, an exposed `/server-status` page, an exposed `/info.php` page showing `phpinfo()`, a browsable `/static/` folder, and a possible remote file inclusion (RFI) pattern in `info.php?file=`. It also showed the exact Apache version (2.4.58).

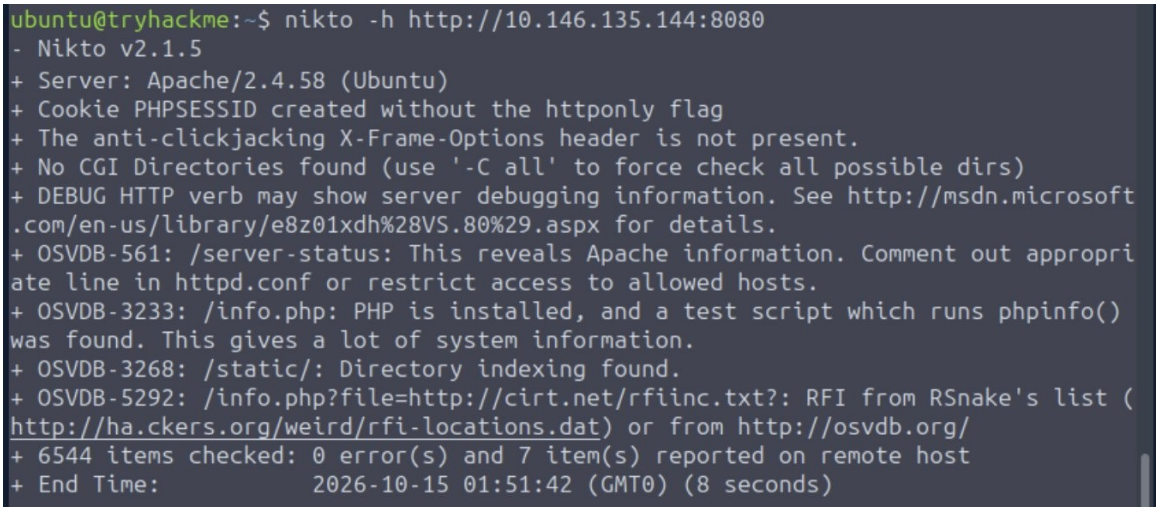


Figure 2: Nikto output against port 8080 (6,544 checks, 7 items).

OpenVAS. The pre-scanned `MyTarget` report gave an overall score of 6.4 (Medium), with 0 Critical, 0 High, 4 Medium and 3 Low results. The CVEs tab linked findings to public CVE IDs, and the Operating Systems tab showed Ubuntu 24.04, matching what Nmap saw.

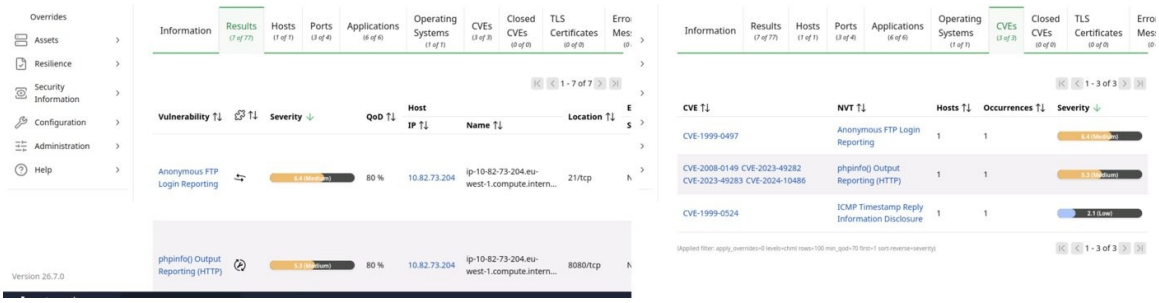


Figure 3: OpenVAS Results and CVEs tabs for the MyTarget report.

Findings and fixes. Scores are the CVSS values OpenVAS gave. Where there was no score, the priority is my own judgement.

Finding	Found by	Severity	Recommended fix (S1)
Anonymous FTP login (port 21)	Nmap script, Nmap -A, OpenVAS	6.4 Medium (CVE-1999-0497)	Disable anonymous access; use SFTP or FTPS.
phpinfo() page at /info.php	Nikto, OpenVAS	5.3 Medium (includes CVE-2008-0149)	Remove it from production.
Session cookie without HttpOnly	Nmap -A, Nikto	Not scored; my priority: medium	Set HttpOnly and Secure flags.
Possible RFI via info.php?file=	Nikto	Not scored; unverified, high until checked	Validate input; verify by hand first.
Missing X-Frame-Options, /static/ indexing, DEBUG method, /server-status, version banner	Nikto	Not scored; my priority: low to medium	Add the header, disable listings and unneeded methods, restrict status pages, patch Apache.
ICMP timestamp disclosure	OpenVAS	2.1 Low (CVE-1999-0524)	Filter ICMP timestamp requests.

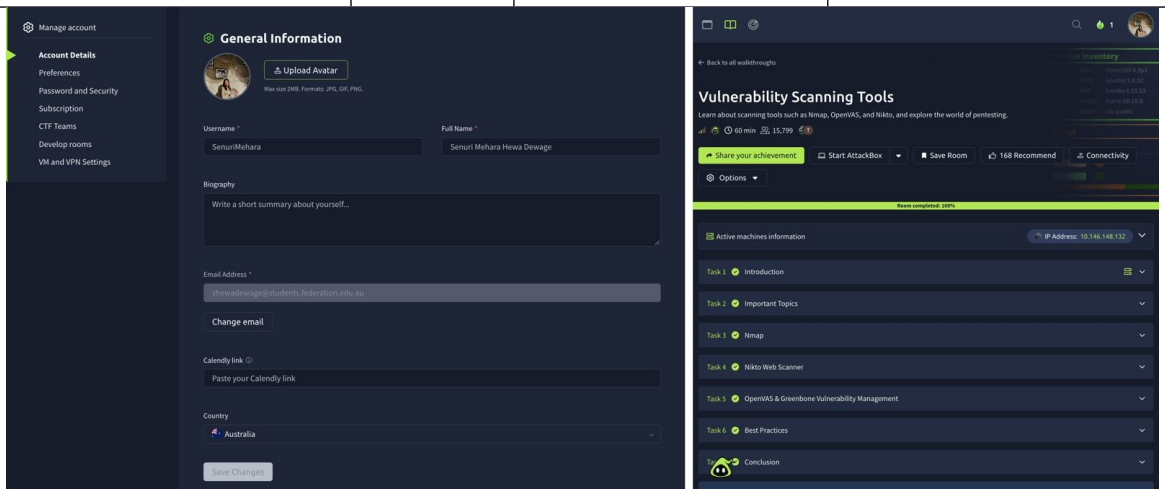


Figure 4: My TryHackMe account (FedUni email) and the 100% room completion page.

The tools backing each other up was the most useful result: Nmap and Nikto both found the cookie problem, Nikto and OpenVAS both found phpinfo, and Nmap and OpenVAS both found anonymous FTP. A finding seen by two tools is more likely to be real, so I would check the RFI line by hand before trusting it.

6. Reflection

What did I learn about cybersecurity concepts and tools?

Each tool answers a different question: Nmap shows what is exposed, Nikto shows what is wrong inside the web server, and OpenVAS shows how serious it is using CVE IDs and CVSS scores. I also learned the difference

between software bugs that need patches and misconfigurations, like anonymous FTP or a missing cookie flag, that a settings change can fix. Scanner output is a set of clues, not proof: Nikto's RFI line is only a pattern match, and Nmap could not fully identify port 80. Even the OpenVAS login page taught me something, because it warned the connection was unencrypted and used default login details, so security tools need securing too. What surprised me most was how quickly real weaknesses appeared: Nikto ran 6,544 checks in about eight seconds, and the most serious OpenVAS finding was not a clever attack but an FTP server that let anyone log in.

The practical challenges were useful too. The connection error taught me that 127.0.0.1 means the machine you are on, and the restart and failed OpenVAS scan taught me to check my environment before blaming the tool.

How will this contribute to my professional growth?

I want to become a SOC analyst, and this exercise practised what that job needs: reading technical output, deciding what matters and explaining it clearly. Fixing the most serious problems first is the heart of vulnerability management and supports the Identify and Protect parts of NIST CSF 2.0 from this unit. Keeping evidence as I worked and staying within an authorised target are habits I will carry into work.

What would I do differently?

I would run a full OpenVAS scan with internet access, ideally logged in, and compare it with a scan that is not. I would also check one finding by hand in the lab, such as logging in to the FTP server, and re-scan after fixes to show the risk dropped. Finally, I would revise the networking and web basics before starting.

7. Portfolio and References

Portfolio (GitHub): https://github.com/Mehara26/Cybersecurity-Portfolio. It holds this project's write-up, report and screenshots in the `itech1502-final-project` folder.

References

- Criminal Code Act 1995 (Cth) pt 10.7 (Computer offences).
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce.
- TryHackMe. (n.d.). *Vulnerability Scanning Tools* [Online training room]. https://tryhackme.com/room/vulnerabilityscanningtools